

TLP:WHITE - APPROVED FOR PUBLIC RELEASE

AI and the Weaponisation of Zero-Day Vulnerabilities

Separating Signal from Narrative

A Cross-Correlation Analysis of AI Model Availability, Exploitation Telemetry,
and Vulnerability Discovery Trends (2022-2026)

COMPANION INTERACTIVE DASHBOARD

Live data visualisations and cross-correlation analysis

<https://greycardinal45.github.io/ai-hydra-tracker/cve-analysis/>

Authors: Darren Humphries, Jerry Clement-Howe, Aniekan Andrew-Essien, Alfred Christopher

Date: 6 June 2026

Classification: TLP:WHITE

Version: 0.8

Keywords: zero-day, vulnerability, AI, LLM, weaponisation, exploitation, MDASH, Glasswing, CVE, KEV, benchmark

Abstract

This paper investigates whether artificial intelligence is genuinely accelerating the weaponisation of software vulnerabilities, or whether the prevailing narrative has outrun the available evidence. Through ten completed research rounds and cross-correlation of six independent data streams — Mandiant incident response telemetry, Verizon breach data, CISA Known Exploited Vulnerabilities catalogue, Microsoft Patch Tuesday release data, Google Threat Intelligence Group zero-day tracking, and NVD vulnerability classification trends — the analysis identifies a critical three-way separation in the evidence that the current discourse consistently conflates.

The first claim, that AI accelerates the operational tempo of cyber attacks, is supported by multi-year telemetry showing exploitation speed compressing dramatically — from median dwell times of 78 days (2018) to an estimated mean time-to-exploit of negative seven days (2025). The second claim, that AI increases the volume of zero-day vulnerabilities, is not supported: zero-day counts have stabilised within a 60–100 annual range with no inflection at any AI capability milestone, and the ratio of confirmed-exploited vulnerabilities to total CVEs published remains flat at approximately 0.5%. The third claim, that AI assists defenders in finding more severe vulnerabilities, is supported and represents the only non-linear signal in any dataset examined, with critical vulnerability severity spiking 3.3 times above baseline in the first months following deployment of vendor AI scanning harnesses.

The paper further defines a three-tier benchmark threshold for vulnerability identification capability, maps Eastern and Western AI model families against these thresholds, and establishes a baseline for ongoing monitoring of whether defensively-discovered vulnerabilities create a perverse feedback loop through accelerated patch reverse-engineering. Six additional research rounds are identified as pending; the paper argues that their completion would not alter the core three-claim separation that constitutes the primary finding.

Keywords: zero-day, vulnerability, AI, LLM, weaponisation, exploitation, MDASH, Glasswing, CVE, KEV, benchmark

1. Introduction

The cybersecurity industry entered 2026 amid an intensifying narrative that artificial intelligence was transforming the offensive threat landscape. Media coverage of Anthropic's Claude Mythos Preview, Google's Threat Intelligence Group report on the first confirmed AI-developed zero-day exploit, and OpenAI's acknowledgement that GPT 5.3-Codex had reached a "High" cybersecurity capability threshold combined to create an environment in which the question was no longer whether AI would change offensive operations but how quickly.

This paper does not dispute that AI capability for vulnerability discovery and exploitation exists. The evidence for that proposition is clear. What this paper investigates is a more precise question: does the aggregate data — mandatory breach disclosures, confirmed exploitation catalogues, vendor patch data, and zero-day tracking — show a measurable change that can be attributed to AI? And if so, which specific claims does it support?

The distinction matters for resource allocation. If AI is primarily accelerating attack speed, the defensive response is different from one predicated on AI expanding the volume of exploitable vulnerabilities. If the strongest measurable signal is defensive discovery rather than offensive exploitation, the investment thesis changes again. The purpose of this analysis is to provide a CISO-level evidence base for distinguishing between these scenarios using verifiable data rather than projection.

1.1 Research Question

The central question under investigation is: **Is AI genuinely accelerating the weaponisation of vulnerabilities, or is the narrative ahead of the evidence?**

This decomposes into three testable sub-questions:

Is the speed of vulnerability exploitation increasing, and does it correlate with AI model availability?

Is the volume of exploited vulnerabilities increasing beyond what organic growth in software complexity would predict?

Is the type and severity of discovered vulnerabilities shifting in ways consistent with AI's known capability profile?

1.2 Scope and Limitations

This analysis is restricted to vulnerabilities and exploitability. It does not address phishing, social engineering, malware evasion, or other attack vectors where AI may have separate and independently measurable effects. The focus on vulnerabilities provides a cleaner analytical signal because vulnerability disclosure, patching, and exploitation have structured reporting mechanisms that other attack categories lack.

The analysis uses publicly available data. It does not have access to classified intelligence, vendor-internal discovery attribution records, or attacker infrastructure analysis. Where data opacity limits the analysis (particularly the 70% of breach notifications that omit attack vector information), this is noted explicitly.

2. Methodology

The investigation proceeded through a structured series of research rounds, each designed to test a specific hypothesis against available data. Each round defined in advance what evidence would support and what evidence would challenge the thesis under test, preventing confirmation bias.

The methodology draws on an investigative-journalism approach: multiple independent data streams are cross-correlated rather than relying on any single source. Where sources conflict, the conflict is reported rather than resolved through selective citation.

Data sources employed:

Source	Type	Coverage	Independence
Mandiant M-Trends 2025/2026	Incident response telemetry	450K–500K+ hours IR annually	Primary — Mandiant's own IR caseload
Verizon DBIR 2024/2025/2026	Breach investigation data	22K+ breaches annually	Primary — Verizon + contributor network
CISA KEV Catalogue	Confirmed exploitation	Federal mandate, evidence-based	Primary — not self-reported
Google GTIG Zero-Day Reviews	Zero-day tracking	Global, 2020–2025	Primary — Google's own research
Microsoft MSRC / Patch Tuesday	Vendor patch data	Monthly, 2025–2026	Primary — vendor disclosure
NVD / CWE Distribution	Vulnerability classification	All published CVEs	Primary — NIST maintained
ITRC Annual Breach Reports	US mandatory disclosures	All US data compromises	Primary — mandatory reporting
UK ICO Breach Data	UK mandatory disclosures	UK organisations	Primary — regulatory filings
BeyondTrust MS Vuln Reports	Microsoft-specific analysis	Annual, 12th/13th editions	Secondary — analytical overlay
AI model benchmark data	Capability measurement	Multiple benchmark suites	Primary — published benchmarks

Ten rounds of analysis were completed. Six additional rounds were defined but remain pending; their scope and hypotheses are documented in Section 11. The paper argues that these pending rounds would refine but not alter the core finding.

3. The Narrative Layer: What Research and Media Report

3.1 The Acceleration Thesis

The prevailing narrative entering 2026 rests on several documented capabilities and incidents. In April 2024, researchers at the University of Illinois Urbana-Champaign demonstrated that GPT-4 could autonomously exploit 87% of 15 real-world one-day vulnerabilities when provided with CVE descriptions, while every other model tested — including GPT-3.5, Llama 2, and Mistral — scored zero (Fang et al., 2024). This established that a capability threshold existed and that GPT-4 had crossed it.

In November 2025, Anthropic documented a Chinese state-sponsored group that had jailbroken Claude Code to launch cyber operations against approximately 30 global targets, with AI automating 80–90% of the operation. Google's Threat Intelligence Group independently documented Chinese threat actor GTG-1002 achieving 80% autonomous operation using LLMs. In February 2026, OpenAI's Preparedness Framework rated GPT 5.3-Codex as the first system to formally reach a "High" cybersecurity threshold.

In April 2026, Anthropic unveiled Claude Mythos Preview, which in a single evaluation run found 271 vulnerabilities in Firefox, developed 181 working exploits, and uncovered a 27-year-old vulnerability in OpenBSD. The model was deemed too capable for public release, leading to the creation of Project Glasswing. On May 11, 2026, Google's Threat Intelligence Group reported the first confirmed case of a criminal group using AI to both discover and weaponise a zero-day vulnerability — a 2FA bypass in an open-source web administration tool, implemented as a Python script with hallmarks typical of LLM-generated code.

3.2 The Counter-Narrative

Not all analysis supports the acceleration thesis at face value. CSIS argued in April 2026 that while autonomous AI zero-day fears are understandable, the urgent problem is more mundane: generative AI is making existing attack methods faster, cheaper, and more accessible. The Mandiant M-Trends 2026 data, while showing dramatic time-to-exploit compression, does not attribute that compression specifically to AI. Multiple confounding variables — the shift to edge device targeting, ransomware-as-a-service maturation, and the explosion in total CVE volume — changed simultaneously.

3.3 Assessment

The narrative is directionally supported by demonstrated capability but relies heavily on individual cases (N=1 for the GTIG AI zero-day, a single documented nation-state campaign) rather than aggregate data. The research rounds that follow test whether aggregate data confirms or challenges the narrative.

4. Disclosure-to-Exploitation Timelines

4.1 The Macro Compression

The most widely cited data point supporting the acceleration thesis is the compression of mean time-to-exploit (TTE). Mandiant's M-Trends reports document the following trajectory:

Period	Mean TTE	Source
2018–2019	63 days	Mandiant M-Trends
2024	5 days	Mandiant M-Trends 2025
2025	–7 days (exploited before patch)	Mandiant M-Trends 2026

Methodological note: The figures above are widely cited in this form; however, the underlying M-Trends data requires careful interpretation. The 2018–2019 and 2024 figures derive from Mandiant's median dwell time metric (time from compromise to detection), not time-to-exploit in the strict sense (time from disclosure to first exploitation). M-Trends 2019 reported global median dwell time of 78 days (2018 data) and M-Trends 2020 reported 56 days (2019 data), yielding an average of approximately 67 days rather than 63. The 5-day figure from M-Trends 2025 represents the dwell time for adversary-notified incidents — typically ransomware — rather than the global median, which was 11 days. Only the –7 day estimate from M-Trends 2026 appears to measure TTE directly. The overall compression trend is real and directionally consistent across metrics, but this table should not be read as a single continuous time series of the same measurement. M-Trends 2025 drew on more than 450,000 hours of incident response work; M-Trends 2026 drew on over 500,000 hours.*

Complementing this, CrowdStrike's 2026 Global Threat Report documented a 42% year-over-year increase in zero-day vulnerabilities exploited before public disclosure, and VulnCheck identified that 28.96% of the 884 vulnerabilities with first-time exploitation evidence in 2025 were exploited on or before the day their CVE was published — up from 23.6% in 2024.

4.2 Case Studies

Seven CVE-level timelines were examined to test the macro data against individual cases. Selected findings:

CVE-2025-31324 (SAP NetWeaver, CVSS 10.0): Reconnaissance activity began January 20, 2025. Active exploitation confirmed by March 27. Emergency patch released April 24 — 94 days after exploitation began. This represents a pure zero-day scenario where the vulnerability was weaponised and exploited for over three months before any patch existed.

CVE-2024-3400 (Palo Alto PAN-OS, CVSS 10.0): Exploitation began in late March 2024, approximately two weeks before Palo Alto's public disclosure on April 12. Hotfixes followed April 14–19. Mass scanning within days of disclosure.

CVE-2023-23397 (Outlook NTLM, CVSS 9.8): APT28 exploited this as a zero-day for approximately 12 months before Microsoft patched it in March 2023. Commodity n-day exploitation followed within weeks of the patch.

Document-format phishing pipeline: CVE-2017-11882, CVE-2017-0199, CVE-2022-30190 (Follina), and CVE-2023-23397 all demonstrate a consistent pattern: document-format RCEs with low-interaction triggers move from disclosure to commodity phishing payload in single-digit weeks, with a perfect historical track record.

4.3 Assessment

TTE compression is real and documented across multiple independent sources. However, the TTE curve was already declining before GPT-4's release in March 2023. The compression predates AI availability, though AI may be accelerating a pre-existing trend. The case studies demonstrate that both zero-day exploitation (pre-patch) and n-day exploitation (post-patch) are occurring faster, but individual cases cannot isolate AI as the cause.

5. AI Model Availability Correlation

5.1 The Tooling Gap

A critical control that the acceleration narrative often omits is what AI tools were actually available to threat actors at each point in the exploitation timeline. Before mid-2024, the only model with demonstrated exploit capability was GPT-4 — API-gated, logged, and guardrailed. Open-weight models (Llama 2, Mistral 7B) scored 0% on exploit benchmarks. Threat actors could not use GPT-4 for exploitation without leaving traces or being rate-limited.

The inflection point for open-weight offensive capability was January 2025, when DeepSeek released R1 — a 671-billion-parameter reasoning-capable model under an MIT licence. This was the first time a model with sufficient coding and reasoning capability for exploit development was freely downloadable, self-hostable, and operable without guardrails, API logs, or terms of service.

5.2 The Verizon DBIR Correlation

The Verizon Data Breach Investigations Report provides the strongest correlation between AI model availability and exploitation trends. Vulnerability exploitation as an initial access vector for confirmed breaches shows the following progression:

DBIR Year	Data Period	Vuln Exploitation %	YoY Change	AI Context
2023	Nov 2021–Oct 2022	~5%	Baseline	No meaningful AI tooling

DBIR Year	Data Period	Vuln Exploitation %	YoY Change	AI Context
2024	Nov 2022–Oct 2023	14%	+180%	GPT-4 available but API-only
2025	Nov 2023–Oct 2024	20%	+34%	Claude 3.5, GPT-4o, Llama 3.1
2026	Nov 2024–Oct 2025	31%	+55%	Full ecosystem including DeepSeek R1

This progression tracks AI model availability closely. However, correlation does not establish causation. The same period saw a massive shift toward edge device targeting (VPNs, firewalls), ransomware-as-a-service maturation, and a 20.6% year-on-year increase in total CVEs published. Multiple variables changed simultaneously.

5.3 Assessment

The DBIR data provides the strongest circumstantial correlation between AI availability and exploitation trends. The timing is suggestive — the +180% spike in the 2024 DBIR coincides with GPT-4’s first full year of availability — but cannot be isolated from confounding variables. The correlation supports further investigation but does not constitute proof.

6. Breach Disclosure Ground Truth

6.1 Mandatory Reporting Data

If AI were genuinely accelerating attacks, mandatory breach disclosures should show a corresponding increase. The ITRC Annual Data Breach Reports, based on US mandatory disclosure requirements, show:

Year	Data Compromises	YoY Change	5-Year Trend
2021	1,860	—	—
2022	1,802	–3%	—
2023	3,205 (record)	+78%	—
2024	3,158	–1%	—
2025	3,322 (new record)	+5%	+79%

The growth is real but follows a steady upward slope, not the hockey-stick curve that a transformative AI-driven acceleration would produce. Healthcare breaches show consistent 4% annual increases. UK ICO data shows cyber-related breaches rising from 25.9% to 32.5% of total reports.

6.2 The Opacity Problem

A critical finding that undermines all breach disclosure analysis is the accelerating opacity of breach notifications. The percentage of breach notices containing no attack vector information has risen from approximately 0% in 2019 to 40% in 2022, 45% in 2023, 65% in 2024, and 70% in 2025. Seven in ten breach notifications now tell the public nothing about how the breach occurred. This makes it structurally impossible to attribute the increase to any specific cause — AI or otherwise — from disclosure data alone. The opacity is itself a finding worth reporting: the ground truth is being deliberately obscured by reporting organisations that have learned that vague disclosures satisfy legal minimums while limiting liability.

6.3 Assessment

Breach disclosures are increasing but not explosively. The 70% opacity rate renders this dataset inconclusive for attribution purposes. The data neither supports nor challenges the AI acceleration thesis because it lacks the resolution to distinguish causes.

7. CVE Volume, Severity, and the Defensive AI Signal

7.1 The Volume Story

Microsoft patched 1,139 CVEs in 2025, the second-largest annual total. Through May 2026, the year-to-date count (552) runs 17% ahead of the same period in 2025 (470). Total CVEs published in NVD reached 48,185 in 2025, a 20.6% increase over 2024.

BeyondTrust's 13th annual Microsoft Vulnerabilities Report reveals a critical nuance: while total Microsoft CVEs dropped 6% to 1,273 in 2025, critical-rated vulnerabilities surged 16%, from 160 to 186. The pattern is fewer bugs but nastier ones.

7.2 The Severity Inflection

Monthly Microsoft Patch Tuesday data from January 2025 through May 2026 shows 15 months of stable critical vulnerability percentage (averaging approximately 6.8% of total CVEs rated critical) followed by a single dramatic break. In May 2026, critical CVEs reached 22.6% of the total — a 3.3 times spike above the 15-month baseline. This coincides precisely with the public deployment of Microsoft's MDASH (Multi-model Agentic Scanning Harness) and Anthropic's Project Glasswing.

Microsoft confirmed that MDASH discovered 16 of the 137 vulnerabilities fixed in the May 2026 Patch Tuesday release. These were described as 10 kernel-mode and 6 user-mode vulnerabilities in the Windows networking and authentication stack, including 4 rated Critical. MDASH's most severe finding was CVE-2026-33824 (CVSS 9.8), a double-free vulnerability in Windows' IKEEXT service that spanned six source files and was invisible within any single file — detectable only by comparing memory-ownership patterns across files.

Simultaneously, Palo Alto Networks used Claude Mythos to scan their own product portfolio and discovered dozens of previously unknown flaws. Glasswing's 12 launch partners and approximately 40 additional organisations had surfaced over 10,000 high- or critical-severity vulnerabilities within two months of programme launch.

7.3 Assessment

This represents the only non-linear signal in any dataset examined. Every other metric — total CVEs, breach counts, KEV additions, zero-day volume — follows a linear trend. The critical severity spike is the exception, and it maps precisely to defensive AI deployment, not offensive AI activity. The implication is that the measurable AI impact on vulnerability data is currently a defensive story: Tier 1 vendors using AI on their own code are finding deeper, more structurally significant bugs that manual review missed.

8. CISA KEV Velocity: The Flat Ratio

8.1 Annual KEV Growth

The CISA Known Exploited Vulnerabilities catalogue provides the closest approximation to ground truth for "was this vulnerability actually weaponised." Additions require evidence of confirmed exploitation and are not self-reported.

Year	KEV Additions	Total CVEs Published	KEV as % of Total CVEs
2023	187	~29,000	~0.65%
2024	185	40,009	0.46%
2025	245	48,185	0.51%

KEV additions grew 20% in 2025 — but total CVEs grew 20.6%. The ratio barely moved. The proportion of published vulnerabilities that are actually exploited in the wild is essentially flat at approximately 0.5%, regardless of AI availability.

8.2 CWE Distribution in KEV

While the ratio is flat, the composition of what is being exploited shows a pattern consistent with AI capability. Among the top CWEs in 2025 KEV additions, logic-class flaws (command injection, deserialisation, path traversal, XSS, code injection, authentication bypass) accounted for approximately 75% of the most prevalent types, while memory corruption (use-after-free, out-of-bounds write) accounted for approximately 25%. This 3:1 ratio aligns with the AI Hydra framework's assessment that AI can weaponise logic flaws autonomously while memory corruption exploitation still requires human expertise.

8.3 Assessment

The KEV data directly challenges the claim that AI is causing more vulnerabilities to be exploited. The exploitation ratio is flat; KEV growth tracks CVE volume growth, not capability change. However, KEV measures binary exploitation (yes/no) and does not measure exploitation speed. The Mandiant TTE data addresses speed; KEV addresses volume. They measure different phenomena and should not be conflated. The CWE class distribution within KEV is consistent with AI's known capability profile but does not prove AI causation.

9. Vulnerability Class Distribution and the Access Ladder

9.1 The Class Shift

Analysis of NVD CWE distribution from 2020 to 2025 reveals a measurable shift in the types of vulnerabilities being discovered and reported. Missing Authorisation vulnerabilities (CWE-862) surged 62% year-on-year in 2025 to become the fourth most common weakness class at 5.2% of all CVEs. Authorisation and access-control failures have become permanent fixtures in the NVD top tier since 2022. Meanwhile, traditional memory corruption categories have declined as a proportion of total discoveries.

Within the Microsoft ecosystem specifically, Azure and Entra ID accounted for 22% of all critical vulnerabilities in 2025, double their share from 2023. Privilege escalation flaws, traditionally the bedrock of Windows exploitation, dropped from an average of 34% of CVEs (2020–2024) to 28% in 2025.

9.2 Three Competing Explanations

The class shift is real but admits three competing explanations. First, AI scanning tools may be finding logic flaws that human review missed (the defensive discovery thesis). Second, the migration to cloud platforms naturally produces more logic and authorisation code, increasing the denominator of that vulnerability class independent of AI. Third, AI-generated code may itself be introducing authorisation gaps — one analysis noted that the growing prevalence of AI-generated code, which often omits robust permission checks, may be contributing to the CWE-862 trend.

9.3 The Access Ladder

Cross-referencing vulnerability discoverer attribution with AI model access timelines reveals a suggestive pattern. The people finding the surging class of logic and authorisation vulnerabilities are disproportionately the people who had early access to frontier AI tools.

The access ladder defines five tiers:

Tier	Access Level	When Available	Observable Effect
0	Vendor proprietary AI (Big Sleep, MDASH)	2024–2025	SQLite zero-day (2024), 16 MDASH CVEs (May 2026)

Tier	Access Level	When Available	Observable Effect
1	Glasswing / Mythos (restricted consortium)	Apr 2026	10,000+ high/critical vulns in 2 months
2	Elite researchers + commercial AI	Mid-2023 onward	CWE-862 surge, Entra ID CVSS 10.0
3	Open-weight capable (DeepSeek R1, self-hosted)	Jan 2025	Not yet distinguishable in aggregate data
4	General commercial (Opus 4.6, GPT-5)	Q1 2026	Not yet observable
5	Everyone else (free/cheap models)	Ongoing	Not applicable to vulnerability discovery

The CWE-862 authorisation flaw surge in 2025 — the single biggest class shift in NVD data — aligns with when Tier 2 researchers had 12 or more months of commercial AI access. The May 2026 critical severity spike aligns with Tier 0–1 deploying Glasswing and MDASH. Effects appear to cascade down the access ladder with approximately 12-month lag per tier. The people finding the bugs are the people who had the tools first. This is circumstantially strong for causality but would require discoverer confirmation to constitute proof.

10. East vs West AI Capability Benchmarking

10.1 Defining the Vulnerability Identification Threshold

The Fang et al. result — GPT-4 at 87% exploit success versus 0% for every other model — represents a step function, not a gradient. Analysis of the benchmark profiles of models at the time of that test suggests the threshold is a combination requirement: approximately HumanEval greater than 60%, MATH greater than 45%, and multi-step reasoning capability, all simultaneously. Below this combination, models cannot perform meaningful vulnerability identification. Above it, they can.

This step function maps to three tiers of vulnerability capability:

Tier	Capability	Benchmark Proxy	First Western	First Eastern
A — Basic vuln ID	Binary classification of vulnerable code	HumanEval >65%, GPQA >35%	GPT-4, Mar 2023	Qwen 2.5, Sep 2024
B — Exploit development	Write working PoC for known CVE	SWE-bench >45%, GPQA >55%	GPT-4+o1, Sep 2024	DeepSeek R1, Jan 2025
C — Zero-day discovery	Find unknown vulns in large codebases	SWE-bench >70%, agent autonomy	Claude Opus 4, mid-2025	GLM-5, late 2025

10.2 The Closing Gap

The lag between Western and Eastern models crossing each capability tier has compressed dramatically:

Tier	Gap
A (basic vuln ID)	~18 months (Mar 2023 → Sep 2024)
B (exploit development)	~4 months (Sep 2024 → Jan 2025)
C (zero-day discovery)	~3–6 months (mid-2025 → late 2025)

The UK AI Security Institute's Frontier AI Trends Report independently confirms this convergence, finding that the performance gap between open and closed source models has narrowed to between four and eight months. The capability for vulnerability identification is not concentrated in Western laboratories. DeepSeek R1 crossed the Tier B threshold in January 2025 under an MIT licence. GLM-5 crossed Tier C with a SWE-bench score of 77.8%. These are freely downloadable, self-hostable, and operable without guardrails.

10.3 Zero-Day Volume Does Not Correlate with Eastern AI Availability

Despite Eastern models reaching each capability tier, zero-day exploitation volume shows no corresponding inflection. The following table consolidates GTIG tracking data from 2021 to 2025, with attribution detail where available:

Year	Total Zero-Days (GTIG)	Attributable	PRC-Attributed	PRC as % of Attributed	Eastern AI Tier Available
2021	81 (then-record)	—	—	—	None
2022	55	13 state-sponsored	Dominant share	Highest among state actors	None
2023	100 (new record)	—	12	—	None
2024	78	—	5 (dropped)	—	Tier A reached (late year)
2025	90	42 total	10 (rebounded)	~67% of state-sponsored	Tier B all year

10.3.1 The 2025 Attribution Breakdown

The 2025 data is the most granular available. Of 90 total zero-days tracked by GTIG, exploitation could be attributed for 42. The breakdown by actor type is as follows:

Actor Category	Count	Notes
Commercial surveillance vendors (CSVs)	15 (+ 3 likely)	First year CSVs exceeded state-sponsored groups
State-sponsored espionage — PRC-nexus	7 definitive + 3 likely (10 total)	Double the 5 attributed in 2024; highest since 12 in 2023
State-sponsored espionage — other	2	Russia, UAE, and others
Financially motivated	9	Nearly double the 5 in 2024; includes 2 ransomware operations
Dual espionage/cybercrime	1	—
Unattributed	48	Over half of all zero-days remain unattributed

PRC-nexus groups were responsible for at least 10 of 15 state-sponsored zero-days — approximately two-thirds of all government-attributed exploitation. This keeps China as the most prolific state-sponsored user of zero-day exploits over the past decade, though 2025's total of 10 remains below the pre-AI peak of 12 in 2023.

10.3.2 China's Edge Device Concentration

PRC-attributed exploitation shows a pronounced structural pattern. An estimated 85% of known zero-day vulnerabilities exploited by Chinese state-sponsored groups since 2021 have targeted public-facing appliances — firewalls, enterprise VPNs, hypervisors, load balancers, and email security tools (Insikt Group / Recorded Future). In 2025 specifically, CrowdStrike reported that 67% of vulnerabilities exploited by China-nexus adversaries provided immediate system access, and 40% targeted edge devices that typically lack comprehensive endpoint monitoring. Notable 2025 PRC-linked campaigns included UNC5221 exploiting Ivanti Connect Secure (CVE-2025-0282) and UNC3886 exploiting Juniper MX routers (CVE-2025-21590). A separate PRC group, UNC6201, targeted intellectual property — including source code and proprietary development documents — from technology companies, raising the possibility that stolen IP could be used to discover new vulnerabilities in victim products downstream.

10.3.3 Early 2026 Indicators

No comprehensive 2026 zero-day tally has been published as of June 2026 — the major annual reports (GTIG, Mandiant, VulnCheck) cover full calendar years and will not publish 2026 data until early 2027. However, individually disclosed zero-days in the first half of 2026 show the pattern continuing and potentially intensifying:

CVE	Product	CVSS	PRC-Linked?	Notes
CVE-2026-22769	Dell RecoverPoint for VMs	10.0	Yes — UNC6201	Hardcoded credentials; exploited since mid-2024; Brickstorm/Grimbolt malware deployed
CVE-2026-20127	Cisco SD-WAN	10.0	Yes (assessed)	Authentication bypass; exploited since at least 2023
CVE-2025-20393	Cisco Secure Email Gateway	10.0	Yes — UAT-9686	Exploited since late November 2025
CVE-2026-20700	Apple iOS/iPadOS (dyld)	9.0+	No — DarkSword chain	Exploit chain used in targeted surveillance
CVE-2026-3910/3909	Google Chrome	—	Unattributed	Confirmed exploited in wild, March 2026
CVE-2026-35616	Fortinet FortiClient EMS	9.1	Unattributed	Exploited before advisory; CISA KEV 6 April 2026
CVE-2026-21643	Fortinet FortiClient EMS	9.1	Unattributed	Pre-auth SQL injection; second Fortinet zero-day in days
2 × SharePoint zero-days	Microsoft SharePoint Server	—	Unattributed	Patched April 2026 Patch Tuesday
Android zero-day	Android (Framework)	High	Unattributed	Patched June 2026 security update

The 2026 H1 data is incomplete and subject to retroactive attribution, but the pattern is consistent with prior years: PRC-linked groups continue to dominate edge device zero-day exploitation, and overall volume appears on pace with or ahead of 2025. Trend Micro's April 2026 assessment concluded that China's vulnerability reporting regulations — which require 24- to 48-hour mandatory disclosure to state authorities — effectively nationalise vulnerability discovery, likely giving state-aligned groups access to a steady supply of affordable exploits.

10.3.4 Assessment

PRC-attributed zero-days peaked at 12 in 2023 when no Eastern AI had reached any vulnerability identification threshold, dropped to 5 in 2024 when Tier A was reached, and rebounded to 10 in 2025 — still below the pre-AI peak. GTIG describes total zero-day volume as stabilised within a 60–100 annual range. There is no hockey stick. The weapons stockpile is not growing because of AI.

What does correlate with AI availability is the speed of exploitation propagation. GTIG notes that an increasing number of PRC-linked groups are exploiting the same vulnerabilities, suggesting increased exploit sharing or collaborative development. The gap between public disclosure and widespread exploitation by multiple groups is shrinking. This is the speed signal, not the volume signal.

10.4 Assessment

Eastern AI models are at or near parity with Western models on benchmarks relevant to vulnerability identification, with a lag measured in months rather than years. However, zero-day volume does not correlate with AI availability — Eastern or Western. The data supports the conclusion that AI capability for vulnerability work is globally distributed but has not yet produced a measurable increase in the rate of zero-day creation. AI appears to accelerate operational tempo (how fast existing exploits propagate) rather than weapons development (how many new exploits are created).

11. The MDASH Feedback Loop Hypothesis

11.1 The Perverse Question

If defensive AI systems like MDASH and Glasswing are finding vulnerabilities that human review missed, and vendors are patching those vulnerabilities through standard Patch Tuesday processes, the patches themselves become reverse-engineering targets. The question is whether AI-discovered vulnerabilities are weaponised faster than conventionally discovered vulnerabilities from the same release — a perverse feedback loop where defensive AI inadvertently accelerates the n-day problem.

11.2 Baseline Measurement (T+25, June 6, 2026)

The May 2026 Patch Tuesday provides the first test case. Of 137 CVEs in the release, 16 were discovered by MDASH. As of 25 days after release:

CVE Group	Count	Exploited in Wild	Time to Exploitation
MDASH-discovered (AI-found)	16	0 of 16	None yet
Non-MDASH (conventional)	~121	At least 1	17 days

The conventionally discovered CVE-2026-41089 (Windows Netlogon, CVSS 9.8) was confirmed actively exploited on May 29, 2026 — 17 days after patch release. None of the 16 MDASH-discovered CVEs have been confirmed exploited.

11.3 Preliminary Assessment

At T+25, the perverse feedback loop hypothesis is not supported. The AI-discovered bugs have not been weaponised; the conventionally discovered bug was hit first. However, the MDASH-discovered bugs are predominantly memory corruption vulnerabilities (double-frees, use-after-frees, race conditions) in the Windows networking stack, which are inherently harder to exploit than the stack-based buffer overflow in the Netlogon bug. The comparison may be confounded by vulnerability class rather than discovery method.

May 2026 was also the first zero-day-free Patch Tuesday in 22 months. This may itself be evidence that MDASH and Glasswing are preventing zero-days by finding bugs before attackers do. A recheck at T+60 (July 6, 2026) is required to provide more conclusive data.

12. The Three-Claim Separation: Primary Finding

The central contribution of this analysis is the identification that the prevailing AI-and-cybersecurity discourse consistently conflates three distinct claims, each with materially different evidence levels:

Claim 1: AI Accelerates Operational Tempo — SUPPORTED

AI is making cyber attacks faster, not more numerous. Mandiant telemetry shows exploitation speed compressing dramatically across six years — from dwell times measured in months to estimated time-to-exploit of negative seven days in 2025. CrowdStrike documents 22-second initial access handoffs and a 42% year-over-year increase in zero-day exploitation before disclosure. VulnCheck finds 28.96% of exploited CVEs attacked on or before the day their CVE was published. Exploit sharing between PRC-linked groups is accelerating. This is automation of the existing kill chain — faster propagation, faster lateral movement, faster handoff to ransomware affiliates — not the creation of new weapons.

Claim 2: AI Increases Zero-Day Volume — NOT SUPPORTED

Zero-day counts have stabilised within a 60–100 annual range (GTIG, 2021–2025: 81→55→100→78→90). The record year (2023, 100 zero-days) occurred when no AI model had reached the vulnerability identification threshold. PRC-attributed zero-days peaked at 12 in 2023 and do not correlate with Eastern AI capability milestones; even the 2025 total of 10 (representing two-thirds of all state-sponsored attribution) remains below the pre-AI peak. The CISA

KEV-to-CVE ratio remains flat at approximately 0.5%. The proportion of vulnerabilities that are actually exploited is not increasing. AI has not expanded the weapons stockpile.

Claim 3: AI Enhances Defensive Discovery — SUPPORTED (Strongest Signal)

The only non-linear inflection in any dataset examined is the May 2026 critical severity spike (22.6% vs 6.8% baseline), which maps precisely to the deployment of MDASH and Glasswing. Project Glasswing partners surfaced over 10,000 high- or critical-severity vulnerabilities in two months. The CWE-862 authorisation flaw surge aligns with elite researchers having 12-plus months of commercial AI access. The access ladder shows effects cascading down from those who got AI tools first. Defensive AI is the measurable story; offensive AI is the narrative.

12.1 Why This Distinction Matters

If a CISO acts on Claim 1 (speed), the investment goes to detection speed, automated response, and reducing mean time to contain. If a CISO acts on Claim 2 (volume), the investment goes to broader vulnerability scanning and expanded patch coverage. If a CISO acts on Claim 3 (defensive discovery), the investment goes to deploying AI scanning tools on internal code and accelerating patch cycle for AI-discovered critical flaws.

The data says: invest in speed (Claim 1 is real) and deploy defensive AI scanning (Claim 3 is the strongest signal). Do not assume that the volume of exploitable vulnerabilities is expanding beyond organic growth (Claim 2 is not supported). The 32-day median patch cycle is structurally inadequate against a negative time-to-exploit regardless of whether AI is the cause — the operational reality demands faster patching whether the attribution is proven or not.

13. Cross-Correlation Summary

The following table presents all data streams examined, their trend characteristics, and their relationship to AI capability milestones:

Data Stream	Trend	AI Inflection Visible?	Supports Which Claim?
Mandiant TTE / dwell time	Non-linear compression	Predates AI, may be accelerated	Claim 1 (speed)
Verizon DBIR vuln exploitation %	Linear growth, 5→31%	Correlates with AI availability	Claim 1 (speed)
GTIG zero-day count	Stable 60–100/year (81→55→100→78→90)	No inflection at any AI date	Challenges Claim 2
GTIG zero-day attribution (2025)	42/90 attributed; CSVs led for first time	CSV growth outpaces state-sponsored	Context for all claims
PRC-attributed zero-days	12→5→10 (no AI correlation)	Peak was before AI threshold crossed	Challenges Claim 2
PRC edge device concentration	85% of PRC zero-days target edge since 2021	Structural, not AI-driven	Context for Claim 1
2026 H1 zero-days (preliminary)	Multiple critical; 3+ PRC-linked confirmed	Consistent with prior years	Monitoring
CISA KEV additions	Tracks CVE volume growth	No inflection (ratio flat 0.5%)	Challenges Claim 2
KEV CWE distribution	75% logic / 25% memory	Consistent with AI capability profile	Supports Claim 1 indirectly
ITRC breach disclosures	Steady slope (+79% over 5yr)	No hockey stick at AI dates	Inconclusive
MS Patch Tuesday total CVEs	Roughly flat / slight increase	No inflection	Neutral
MS Patch Tuesday critical %	15 months flat, then 3.3× spike	Yes — at Glasswing/MDASH deployment	Supports Claim 3 (defensive)
NVD CWE-862 (Missing Auth)	+62% YoY in 2025	Aligns with Tier 2 researcher access	Supports Claim 3

Data Stream	Trend	AI Inflection Visible?	Supports Which Claim?
Eastern AI benchmark scores	Closing gap: 18mo → 4mo → 3mo	Models at parity on Tier A–B	Context for all claims
MDASH CVE exploitation (T+25)	0/16 exploited	Too early to assess	R16 pending

14. Pending Research Rounds and Limitations

Six additional research rounds were defined during the investigation. While each would contribute additional granularity, the paper argues that their completion would not alter the three-claim separation that constitutes the primary finding:

Round 6 — Bug Bounty Submission Volume and Severity. Testing whether HackerOne/Bugcrowd submission volumes and severity distributions have shifted since AI tools became viable. This would refine Claim 3 (defensive discovery) by measuring whether AI is visibly changing the researcher ecosystem. It would not affect Claims 1 or 2.

Round 8 — EPSS Calibration Drift. Testing whether the Exploit Prediction Scoring System's predictions are degrading as AI changes attacker capability profiles. This would refine understanding of Claim 1 (speed) but would not establish or challenge volume claims.

Round 9 — Vendor Self-Discovery Ratios. Testing whether the proportion of CVEs found internally versus externally is shifting at vendors deploying AI scanning. This would strengthen or weaken Claim 3. MDASH's 16/137 in May 2026 (approximately 12%) is the first data point.

Round 11 — CVE-to-PoC Timing. Measuring whether the time from CVE publication to public proof-of-concept availability on ExploitDB or GitHub is compressing. This directly addresses Claim 1 (speed) and could provide class-level data (logic flaws vs memory corruption). It would not affect Claim 2.

Round 12 — Zero-Day Broker Market Disruption. Zerodium disabled its website in January 2025. If AI is commoditising exploit discovery, the exclusive broker business model may be disrupted. This is an indirect market signal that would not change the aggregate data findings.

Round 13 — Patch Bypass and Variant Clustering. Testing whether CVE clusters (multiple related vulnerabilities in the same component, same release window) are increasing. The May 2026 Word cluster (four Critical RCEs with identical CVSS profiles exploitable via Preview Pane) is a potential case study. This would refine Claim 3 by testing whether AI enables faster variant discovery after initial patches.

Round 16 — MDASH Patch Reverse-Engineering Speed (Baseline Set). A baseline was established on June 6, 2026, at T+25 days from the May Patch Tuesday. Zero of 16 MDASH-discovered CVEs had been exploited, versus at least one conventionally discovered CVE exploited at T+17. A recheck at T+60 (July 6, 2026) is required.

None of these pending rounds would, if completed, establish a volume-based acceleration thesis (Claim 2) given that the KEV ratio and zero-day volume data directly contradict it. They would refine the speed thesis (Claim 1) and the defensive discovery thesis (Claim 3) but would not change the fundamental three-way separation.

15. Conclusions

This analysis began with a single question: is AI genuinely accelerating the weaponisation of vulnerabilities? The honest answer is more nuanced than either the acceleration narrative or its sceptics suggest.

AI is demonstrably accelerating the operational tempo of cyber attacks. The compression of time-to-exploit from months to days to negative values is the most significant structural change in the defender's operating environment in decades. Whether AI is the primary cause of this compression or merely one of several concurrent factors does not change the operational reality: a 32-day median patch cycle is structurally inadequate against a threat landscape

where exploitation routinely precedes disclosure.

AI is not demonstrably increasing the volume of zero-day exploitation. The data across five years of Google GTIG tracking shows stabilisation within a 60–100 range (81 in 2021, 55 in 2022, 100 in 2023, 78 in 2024, 90 in 2025). PRC-attributed zero-days peaked at 12 in 2023 — before any Eastern AI model reached the vulnerability identification threshold — dropped to 5 in 2024, and rebounded to 10 in 2025. Even with full 2025 attribution data showing PRC groups responsible for 10 of 15 state-sponsored zero-days, the absolute volume does not correlate with AI capability milestones. The CISA KEV-to-CVE ratio is flat. The weapons stockpile is not growing because of AI. What has changed is concentration: PRC exploitation is overwhelmingly focused on edge devices (85% since 2021), and early 2026 disclosures — including CVSS 10.0 zero-days in Cisco and Dell infrastructure — show this structural pattern continuing.

AI is demonstrably enhancing defensive vulnerability discovery, and this is the strongest measurable signal in any dataset examined. The critical severity spike in May 2026, the CWE-862 authorisation flaw surge, and the access ladder correlation between AI tool availability and discoverer attribution all point to the same conclusion: the people finding the bugs are the people who got AI tools first, and they are finding deeper, more structurally significant bugs than manual review produced.

The capability for vulnerability identification is globally distributed. Eastern AI models have reached parity with Western models at the basic and exploit development tiers, with a 3–6 month lag at the zero-day discovery tier. The benchmark threshold for vulnerability identification is a step function — models either can or cannot — and that threshold has been crossed by models available under permissive open-source licences.

The three-claim separation — speed (supported), volume (not supported), defensive discovery (supported, strongest signal) — is the primary analytical contribution of this paper. Conflating these three phenomena, as much of the current discourse does, leads to misallocation of defensive resources. The data says: patch faster, deploy defensive AI, and do not assume the attack surface is expanding beyond organic growth.

The question for the next 12 months is whether Claim 3 (defensive discovery) creates an unintended acceleration of Claim 1 (speed) through a perverse feedback loop in which more patches create more reverse-engineering targets. The MDASH baseline established in this paper provides the framework for testing that hypothesis. The answer will determine whether defensive AI is an unqualified good or a capability with second-order consequences that the industry has not yet confronted.

References

- Anthropic. (2026, April 7). *Project Glasswing: Securing critical software for the AI era*. <https://www.anthropic.com/project/glasswing>
- Anthropic. (2026, June 2). *Expanding access to Project Glasswing*. CyberScoop coverage.
- BeyondTrust. (2025, April). *12th Annual Microsoft Vulnerabilities Report*. <https://www.beyondtrust.com/resources/whitepapers/microsoft-vulnerability-report-2025>
- BeyondTrust. (2026, April 21). *13th Annual Microsoft Vulnerabilities Report*. <https://www.beyondtrust.com/resources/whitepapers/microsoft-vulnerability-report>
- CrowdStrike. (2026, February). *2026 Global Threat Report*.
- CrowdStrike. (2026, February 24). *2026 CrowdStrike Global Threat Report: AI Accelerates Adversaries and Reshapes the Attack Surface*. <https://www.crowdstrike.com/en-us/press-releases/2026-crowdstrike-global-threat-report/>
- Cyble. (2026, January 2). *2025 CISA KEV Catalog Hits 1,484 Exploited Vulnerabilities*. <https://cyble.com/blog/cisa-kev-2025-exploited-vulnerabilities-growth/>
- Fang, R., Bindu, R., Gupta, A., & Kang, D. (2024). *LLM Agents Can Autonomously Exploit One-Day Vulnerabilities*. University of Illinois Urbana-Champaign. arXiv preprint.
- Google Threat Intelligence Group. (2025, April 29). *Hello 0-Days, My Old Friend: A 2024 Zero-Day Exploitation Analysis*. <https://cloud.google.com/blog/topics/threat-intelligence/2024-zero-day-trends/>
- Google Threat Intelligence Group. (2026, March 5). *Look What You Made Us Patch: 2025 Zero-Days in Review*. <https://cloud.google.com/blog/topics/threat-intelligence/2025-zero-day-review>
- Google Threat Intelligence Group. (2026, May 11). *Adversaries Leverage AI for Vulnerability Exploitation, Augmented Operations, and Initial Access*. <https://cloud.google.com/blog/topics/threat-intelligence/ai-vulnerability-exploitation-initial-access>

Identity Theft Resource Center. (2025, January 28). *2024 Annual Data Breach Report*.
<https://www.idtheftcenter.org/post/2024-annual-data-breach-report-near-record-compromises/>

Identity Theft Resource Center. (2026, January 29). *2025 Annual Data Breach Report*.
<https://www.idtheftcenter.org/post/2025-annual-data-breach-report-record-number-compromises/>

Mandiant. (2025, March). *M-Trends 2025*.

Mandiant. (2026, March 24). *M-Trends 2026*. <https://www.helpnetsecurity.com/2026/03/24/mandiant-m-trends-2026-report/>

Microsoft Security Response Center. (2026, May 12). *Security Update Guide, May 2026 release*.

Microsoft. (2026, May 12). *MDASH: Multi-model Agentic Scanning Harness*.
<https://thehackernews.com/2026/05/microsofts-mdash-ai-system-finds-16.html>

Microsoft. (2026, June 2). *MDASH Gains Defender Integration at Build 2026*. <https://www.techtimes.com/articles/317692/20260603/microsoft-mdash-gains-defender-integration-build-2026-9655-cybergym-benchmark.htm>

Mondoo. (2026). *2026 State of Vulnerabilities*. <https://mondoo.com/vulnerability-intelligence/state-of-vulnerabilities-2026>

Palo Alto Networks. (2026, May). *Defender's Guide to the Frontier AI Impact on Cybersecurity: May 2026 Update*.
<https://www.paloaltonetworks.com/blog/2026/05/defenders-guide-frontier-ai-impact-cybersecurity-may-2026-update/>

RAND Corporation. (2026, June). *Investigating the potential use of frontier AI models for offensive cyberattacks: A human uplift study*.
RR-A3892-1. https://www.rand.org/pubs/research_reports/RR-A3892-1.html

Stingrai. (2026, June 1). *Vulnerability Statistics 2026: CVE, KEV, Time to Exploit*. <https://www.stingrai.io/blog/vulnerability-statistics-2026>

The Hacker News. (2026, May 4). *2026: The Year of AI-Assisted Attacks*.
<https://thehackernews.com/2026/05/2026-year-of-ai-assisted-attacks.html>

UK AI Security Institute. (2025, December). *Frontier AI Trends Report*. <https://aisi.gov.uk/frontier-ai-trends-report>

UK AI Security Institute. (2026, May). *How fast is autonomous AI cyber capability advancing?*
<https://www.aisi.gov.uk/blog/how-fast-is-autonomous-ai-cyber-capability-advancing>

Verizon. (2024, May). *2024 Data Breach Investigations Report*.

Verizon. (2025, April). *2025 Data Breach Investigations Report*.

Verizon. (2026, May). *2026 Data Breach Investigations Report*.
<https://www.scworld.com/news/verizon-dbir-2026-vulnerability-exploits-top-initial-access-as-patching-coverage-falls>

VulnCheck. (2026). *2025 Exploitation Data*. Cited in CSO Online coverage.

VulnCheck. (2026, January 21). *State of Exploitation 2026*. <https://www.vulncheck.com/blog/state-of-exploitation-2026>

Insikt Group / Recorded Future. (2024). *Zero-Days in Edge Devices Become China's Cyber Warfare Tactic of Choice*. Cited in Dark Reading coverage, December 2024.

Trend Micro. (2026, April). *Edge Under Siege: How State-Sponsored Actors Exploit Your Perimeter*. <https://www.trendmicro.com/vinfo/us/security/news/cybercrime-and-digital-threats/edge-under-siege-how-state-sponsored-actors-exploit-your-perimeter>

Zafran. (2026, January 8). *The 2025 Spike in Vulnerabilities Isn't the Full Story*.
<https://www.zafran.io/resources/the-2025-spike-in-vulnerabilities-isnt-the-full-story>

Appendix A: Research Round Index

Round	Topic	Status	Section
R1	Research and media narrative	Complete	Section 3
R2	Disclosure-to-exploit timelines	Complete	Section 4
R3	AI availability correlation	Complete	Section 5
R4	Breach disclosure volumes	Complete	Section 6
R5	CVE volume and severity vs AI launches	Complete	Section 7
R7	CISA KEV velocity	Complete	Section 8
R10	Vulnerability class distribution	Complete	Section 9
R14	East vs West AI capability	Complete	Section 10
R15	Benchmark threshold for vuln ID	Complete	Section 10
R16	MDASH feedback loop (baseline)	Baseline set	Section 11
R6	Bug bounty data	Pending	Section 14
R8	EPSS calibration drift	Pending	Section 14
R9	Vendor self-discovery ratios	Pending	Section 14
R11	CVE-to-PoC timing	Pending	Section 14
R12	Zero-day broker disruption	Pending	Section 14
R13	Patch bypass / variant clustering	Pending	Section 14

COMPANION INTERACTIVE DASHBOARD

Live data visualisations and cross-correlation analysis

<https://greycardinal45.github.io/ai-hydra-tracker/cve-analysis/>

TLP:WHITE - Approved for public release and unlimited distribution

Copyright 2026. This paper draws on commercial and open-source intelligence, applied through an investigative-journalism methodology and cross-referenced against primary sources. The views expressed are those of the authors.